

Kit de Plantillas de Políticas GRC

Alberto Al Leiva

1 de agosto de 2026

Table of Contents

GRC Policy Planlate Toolkit

Este kit de herramientas contiene plantillas de arranque educativas. No constituye asesoramiento legal, regulatorio, privacidad, trabajo, contabilidad, certificación o auditoría formal. Cada plantilla debe ser adaptada, revisada, aprobada, implementada y demostrada para la organización que adopta.

Gobernanza de políticas y Jerarquía de documentos

Propósito

Las políticas establecen la dirección de gestión, los principios obligatorios, la rendición de cuentas y los límites. Deben ser lo suficientemente concisos para gobernar las decisiones y lo suficientemente estables para seguir siendo útiles a medida que cambien la tecnología y los procedimientos.

Una plantilla de políticas no es una política adoptada. La adopción requiere un análisis específico de la organización, la implicación responsable, el examen apropiado, la aprobación oficial, la comunicación, la aplicación y las pruebas retenidas.

jerarquía de documentos

Una jerarquía práctica distingue:

- **Policia:** dirección y principios obligatorios aprobados por la administración autorizada.
- **Standard** - requisitos obligatorios y mensurables de apoyo a la política.
- **Procedimiento** - dio pasos para realizar una actividad.
- **** Directriz**** — práctica recomendada cuando se permite la discreción.
- **Plan** — roles, acciones, recursos y tiempo para un escenario definido.
- **Record** - evidencia de que se produjo una actividad, decisión o control.

No coloque valores detallados de configuración, cambie rápidamente los contactos o indique paso a paso una política de alto nivel a menos que la gobernanza los requiera allí.

Metadatos de política mínima

Toda política controlada debería determinar:

- título e identificador único;
- versión y estado;
- - Propietario de políticas;
- - a) Aprobación de autoridad;
- aprobación y fechas efectivas;
- próxima fecha de examen;
- clasificación;
- entidades aplicables, grupos de trabajo, emplazamientos, sistemas y datos;
- normas, procedimientos, planes y registros conexos;
- - i) la autoridad de excepción;
- historia de revisión.

Funciones de gobernanza

Consejo de Administración o dirección ejecutiva

Aprueba el apetito de riesgo, la dirección de políticas y las excepciones materiales según la autoridad delegada.

Policy owner

Mantiene contenido, coordina revisión, confirma implementación, monitorea excepciones e inicia revisión.

Propietarios de control y procesos

Implementar requisitos, operar controles, retener pruebas e informar de incumplimiento o barreras.

Legal, privacidad, recursos humanos, cumplimiento, registros y especialistas laborales

Examinar las esferas de su competencia. Su examen es necesario cuando una política afecta a los derechos legales, la vigilancia, la privacidad, el empleo, las investigaciones, la retención, el procesamiento transfronterizo, los convenios colectivos o la actividad reglamentada.

Auditoría interna o garantía independiente

Puede evaluar la gobernanza y la aplicación, pero no debe asumir silenciosamente la propiedad de la gestión de la política.

Principios de diseño de políticas

Una política útil es:

- alineados con objetivos y riesgos;
- clara sobre el lenguaje obligatorio versus recomendado;
- medible cuando sea posible;
- realista para las capacidades de la organización;
- de conformidad con otros documentos controlados;
- la tecnología neutral, cuando proceda;
- explícita sobre la rendición de cuentas y las excepciones;
- apoyados por procedimientos, sistemas, capacitación y registros;
- examinados cuando las obligaciones o el cambio de riesgo.

Idioma obligatorio

Use **must** or **shall** for mandatory requirements and **should** for recommendations. Evite expresiones vagas como “según sea necesario”, “regularmente”, o “apropiado” a menos que se definan criterios o juicio delegado.

Alcance y aplicabilidad

Defina quién y qué cubre la política. Considere empleados, contratistas, trabajadores temporales, pasantes, voluntarios, proveedores de servicios, filiales, empresas conjuntas, servicios en la nube, tecnología operativa, dispositivos móviles, trabajo remoto e información en todos los formatos.

Relación con el derecho y los contratos

Las políticas no deben presumir que la norma de una jurisdicción se aplica universalmente. Recordar las entidades jurídicas y jurisdicciones aplicables, y exigir adiciones locales cuando el empleo, la privacidad, la vigilancia, la notificación de incumplimiento, la retención, la accesibilidad o las reglas del sector difieren.

Conflictos normativos

Establecer una vía de escalada de conflictos entre leyes, reglamentos, contratos, políticas, normas y limitaciones operacionales. No dirija al personal que viole una obligación de mayor prioridad. Recordar la decisión y exigir medidas compensatorias.

Adaptación de plantillas, aprobación y publicación

Propósito

Una plantilla debe convertirse en un documento controlado específico de la organización antes de que se base en ella. Los titulares de puestos, cláusulas opcionales, frecuencias de ejemplo y roles genéricos deben resolverse mediante revisión documentada.

Adaptation workflow

1. Identificar a la entidad jurídica, las jurisdicciones, las unidades de negocio, los sistemas, los datos, la fuerza de trabajo y los terceros en alcance.
2. Map applicable laws, regulations, contracts, standards, customer commitments, and internal risk decisions.
3. Assign an accountable policy owner and drafting team.
4. Resolver cada titular y cláusula opcional.
5. Armonizar la terminología con la jerarquía de documentos y el modelo operativo de la organización.
6. Confirme que existen o se financian los procedimientos, la tecnología, la dotación de personal, la capacitación y los registros necesarios.
7. Realizar un examen legal, de privacidad, recursos humanos, registros, cumplimiento, seguridad y accesibilidad, según corresponda.
8. Resolver conflictos y registrar decisiones materiales.
9. Obtener la aprobación de la autoridad delegada.
10. Publicar a través del repositorio controlado, comunicar, entrenar, implementar y retener evidencia.

Controles de marcadores de posición

Las plantillas utilizan campos entre corchetes como [ORGANIZATION], [POLICY OWNER], [TIME PERIOD] y [APPROVING AUTHORITY]. Un cheque de liberación debe fallar cuando los titulares de lugar no resueltos permanecen, excepto cuando un formulario aprobado incita intencionalmente al usuario a obtener datos.

Cláusulas opcionales

Las cláusulas optativas deben ser seleccionadas sobre la base de riesgos y obligaciones, no copiadas automáticamente. Eliminar instrucciones y notas de redacción de la versión aprobada. Recordar por qué se incluyeron, modificaron o omitieron cláusulas materiales.

Pruebas de revisión

Retener pruebas de:

- revisores y fechas;
- Comentarios y resoluciones;
- - a) Hipótesis jurídicas o reglamentarias;
- decisiones sobre riesgos;
- autorización;
- versión controlada final;
- comunicación y capacitación;
- de las dependencias de aplicación;
- excepciones y adiciones locales.

Aprobación

La aprobación confirma la dirección de gestión y la rendición de cuentas. No certifica el cumplimiento legal ni la eficacia del control. El registro de aprobación debe identificar la versión, fecha efectiva, plazo de aplicación y cualquier condición.

Publicación

Publicar sólo la copia controlada aprobada. Evitar que los borradores obsoletos aparezcan autorizados. Las políticas aprobadas deben ser buscables, accesibles al público previsto, protegidos de cambios no autorizados y disponibles durante los outages cuando sean operacionales.

Comunicación y reconocimiento

Elija métodos de comunicación proporcionales al impacto. Las políticas de alto impacto pueden requerir capacitación basada en el papel, formatos traducidos o accesibles, reuniones informativas para administradores y reconocimientos. Un reconocimiento prueba recibo o certificado, no comprensión o cumplimiento.

Adiciones locales

Use adiciones locales cuando las leyes, reglas laborales, restricciones de monitoreo, derechos de incumplimiento, requisitos de registros o condiciones operacionales varían. Las adiciones deben determinar la precedencia y no deben debilitar los requisitos institucionales sin autoridad aprobada.

Expedición de emergencia

Una política de emergencia puede utilizar un examen acelerado cuando el retraso crea un riesgo material. Registrar la base, la aprobación temporal, el período efectivo, la comunicación y el plazo para el examen completo. El estado de emergencia no debe ser indefinido.

Aplicación, pruebas, capacitación y vigilancia

Propósito

Una política sólo es eficaz cuando se están operando controles, recursos, procedimientos, capacitación y vigilancia. La publicación por sí sola no establece la aplicación.

Plan de aplicación

Para cada requisito de material, identifique:

- propietario responsable;
- la norma o el procedimiento de apoyo;
- tecnología o dependencia de procesos;
- presupuesto y personal necesarios;

- plazo de aplicación;
- población afectada;
- capacitación o comunicación;
- fuente de pruebas;
- método de vigilancia;
- Ruta de escalada.

Pruebas de aplicación

Las pruebas pueden incluir normas y procedimientos aprobados, exportaciones de configuración, registros de acceso, terminación de la capacitación, registros, informes de examen, registros de incidentes, resultados de pruebas, registros de proveedores, aprobaciones de excepciones, informes de gestión y medidas correctivas.

Las pruebas deben ser auténticas, completas, actuales, rastreables, debidamente protegidas y retenidas según los requisitos aplicables.

Capacitación

La capacitación debe basarse en el papel y fijarse a la fecha efectiva de la política. Las funciones especializadas pueden requerir ejercicios, instrucción técnica o validación de competencias. Mantener alternativas accesibles y ajustes razonables cuando sea necesario.

Supervisión

La vigilancia debe determinar si se aplican y operan los requisitos, no sólo si existe la política. Las medidas útiles incluyen:

- finalización de la aplicación;
- dependencia atrasada;
- volumen de excepción y edad;
- reiteradas violaciones;
- resultados de la capacitación y la evaluación;
- fallas de control;
- tendencias de incidentes o pérdidas;
- el estado de la acción correctiva;
- cuestiones normativas e indicadores de ambigüedad.

Incumplimiento

Defina una escalada justa y constante. El incumplimiento puede derivar de faltas de conducta, requisitos poco claros, recursos no disponibles, defectos del sistema, obligaciones conflictivas o plazos poco realistas. Investigar los hechos y aplicar los procesos de recursos humanos, legales, contractuales y disciplinarios según corresponda.

Automatización y AI

Los instrumentos automatizados pueden ayudar con la distribución, el reconocimiento, la cartografía, la vigilancia y el proyecto de análisis. No deben inventar aprobaciones, conclusiones jurídicas, pruebas de aplicación, excepciones o resultados de examen. La rendición de cuentas humana sigue estando con el propietario y el autor designado.

Accesibilidad e idioma

Proporcionar políticas en formatos e idiomas necesarios por el público previsto. La traducción automatizada es un candidato de publicación, no prueba de la exactitud de la lengua nativa. Las pruebas de accesibilidad en aplicaciones nativas deben realizarse cuando sea necesario.

Mejora continua

Use incidentes, resultados de auditoría, comentarios de los usuarios, cambios legales, fallos de control, cambios tecnológicos y cambios empresariales para mejorar el diseño de políticas. Preserve revision history and avoid silent changes to mandatory requirements.

Excepciones, Revisión, Registros y Ciclo de Vida

Excepciones

Una excepción es una desviación documentada y aprobada de un requisito de política. No debe utilizarse para ocultar el incumplimiento o evitar la financiación de un control conocido indefinidamente.

Un registro de excepción debe identificar:

- políticas y requisitos;
- solicitante y justificación comercial;
- sistemas afectados, personas, datos y período;
- evaluación del riesgo;
- legal, privacy, contractual, and operational review;
- - Controles compensatorios;
- propietario responsable;
- autorización;
- fechas de inicio y expiración;
- frecuencia de vigilancia y examen;
- plan de rehabilitación o salida;
- Condiciones de revocación.

Excepción de autoridad

La autoridad de aprobación debe reflejar el riesgo. Las excepciones de alto riesgo pueden requerir participación ejecutiva, comité de riesgo, legal, privacidad, cliente, regulador o organismo rector. El titular de la política no debe aprobar una excepción fuera de la autoridad delegada.

Los desencadenantes de revisión

Revisar las políticas sobre un ciclo definido y cuando se activan por:

- cambio jurídico o reglamentario material;
- compromisos contractuales nuevos o modificados;
- incidentes o fallos de control;
- importantes conclusiones de la auditoría;
- fusiones, adquisiciones, inmersiones o reestructuración;
- nueva tecnología, IA, nube o tecnología operacional;
- cambios en el procesamiento o la vigilancia de datos;
- cambios laborales o laborales;
- importantes cambios en los proveedores;
- reiteradas excepciones o ambigüedad.

Examen periódico

Un examen debería confirmar la necesidad, el alcance, la propiedad, la coherencia, la aplicación, las pruebas, las excepciones y la armonización con el riesgo actual. “Revisado sin cambios” todavía requiere un registro de fecha y una aprobación responsable según la gobernanza.

Control de revisiones

Mantener un historial de revisión mostrando versión, fecha, resumen, autor, revisores y aprobador. Los cambios materiales deben ser comunicados y pueden requerir readiestramiento o reconocimiento renovado.

Retiro y archivo

Cuando una política es reemplazada o retirada:

- identificar el documento sucesor;
- establecer la fecha de retiro efectiva;
- eliminar copias públicas obsoletas;
- preservar los registros necesarios;
- actualizar mapas, procedimientos, capacitación y contratos;
- comunicar el cambio;
- conservar versiones históricas según los requisitos de registros.

Documentos

Los documentos de política pueden incluir proyectos, observaciones, aprobaciones, revisión jurídica, reconocimientos, capacitación, pruebas de aplicación, excepciones, vigilancia, incidentes, investigaciones y antecedentes de revisión. Clasifique y proteja estos registros; algunos pueden contener información privilegiada, personal, confidencial o confidencial.

métricas y presentación de informes

Report policy status, overdue reviews, unresolved placeholders, implementation gaps, exceptions, recurring noncompliance, training, and corrective actions. Evite las métricas que recompensan la aprobación rápida al ignorar la calidad de aplicación.

secuencia de uso de Toolkit

1. Lea el manual de implementación.
2. Seleccione sólo plantillas aplicables.
3. resolver todos los titulares de puestos y las notas de redacción.
4. realizar un examen jurisdiccional y especializado.
5. aprobar a través de la gobernanza delegada.
6. publicar la copia controlada.
7. implementar procedimientos, controles, capacitación y registros.
8. supervisar el rendimiento y las excepciones.
9. revisar, revisar o retirar mediante la gestión controlada del ciclo de vida.

Plantilla de Política de Seguridad de la Información

**** Nota de redacción:**** Resolver cada campo entre corchetes y obtener legal, privacidad, recursos humanos, cumplimiento, registros, seguridad y revisión de accesibilidad, según sea aplicable antes de la aprobación.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Autoridad de aprobación: [APPROVING AUTHORITY]
- Versión: [VERSION]
- Fecha efectiva: [DATE]
- Siguiendo opinión: [DATE]
- Clasificación: [CLASSIFICATION]

1. Propósito

[ORGANIZATION] establece esta política para proteger la información, la tecnología, los servicios, las personas y los objetivos empresariales mediante controles de gobernanza y seguridad basados en el riesgo.

2. Alcance

Esta política se aplica a [LEGAL ENTITIES, WORKFORCE, CONTRACTORS, LOCATIONS, SYSTEMS, DATA, CLOUD SERVICES, AND THIRD PARTIES].

3. Principios

[ORGANIZATION] debe:

- gestionar el riesgo de seguridad de la información dentro del apetito de riesgo aprobado;
- - c) asignar a los propietarios responsables información, sistemas, servicios y controles;
- aplicar seguridad a través de la adquisición, diseño, desarrollo, operación, cambio y eliminación;
- proteger la confidencialidad, integridad, disponibilidad, autenticidad y resiliencia según el riesgo;
- cumplir con los requisitos legales, regulatorios, contractuales, de privacidad, registros y clientes aplicables;
- mantener las capacidades de incidencia, continuidad, recuperación, proveedor, vulnerabilidad, identidad, registro y monitoreo;
- :: Proporcionar información y capacitación basadas en la función;
- medir el rendimiento y las deficiencias de control;
- documentar y aprobar excepciones.

4. Gobernanza

[GOVERNING BODY OR EXECUTIVE] aprueba la dirección de seguridad y el apetito de riesgo. [CISO OR SECURITY LEADER] coordina el programa de seguridad. Los propietarios de empresas, datos, sistemas, procesos y control siguen siendo responsables de los riesgos y controles dentro de su autoridad.

5. Gestión de riesgos

Los riesgos de seguridad deben identificarse, evaluarse, tratarse, supervisarse e informarse utilizando [RISK METHODOLOGY]. La aceptación del riesgo debe ser aprobada por [AUTHORITY] y revisada por [FREQUENCY].

6. Gestión de activos e información

Los bienes de información y tecnología deben inventarse, asignar propietarios, clasificarse, manejarse, conservarse y disponerse de acuerdo con los requisitos aprobados.

7. Identidad y acceso

El acceso debe ser autorizado, menos privilegiado, revisado periódicamente, cambiado o revocado rápidamente, y protegido con controles de autenticación proporcionados al riesgo.

8. Ciclo de vida de tecnología segura

Los requisitos de seguridad deben incluirse en arquitectura, adquisición, desarrollo, configuración, pruebas, despliegue, cambio, mantenimiento y desmantelamiento.

9. Operaciones y resiliencia

[ORGANIZATION] debe mantener la gestión de vulnerabilidad, protección de malware, respaldo, recuperación, registro, monitoreo, capacidad, configuración, respuesta a incidentes, continuidad y controles de recuperación de desastres proporcionalmente al riesgo.

10. Terceros

Los riesgos de seguridad y privacidad derivados de proveedores y terceros deben evaluarse, abordarse contractualmente, supervisarse y gestionarse mediante rescisión o transición.

11. Reporting

Los incidentes de seguridad sospechosos, los fallos de control, las violaciones de las políticas y los riesgos materiales deben informarse a través de [REPORTING CHANNEL] sin represalias cuando estén protegidos por la ley.

12. Excepciones

Las excepciones requieren justificación documentada, evaluación de riesgos, controles compensatorios, propietario, fecha de vencimiento, vigilancia y aprobación por [EXCEPTION AUTHORITY].

13. Ejecución

Las violaciones pueden dar lugar a medidas correctivas, contractuales o disciplinarias compatibles con la legislación aplicable, los contratos, las normas de la fuerza de trabajo, las garantías procesales y los procedimientos aprobados.

14. Documentos conexos

[LIST STANDARDS, PROCEDURES, PLANS, AND REGISTERS]

15. Examen y aprobación

Esta política debe ser revisada al menos [FREQUENCY] y después de cambios materiales. Los registros de aprobación y el historial de revisión deben mantenerse.

Plantilla de política de control de acceso

Resolver todos los propietarios y revisar el empleo, privacidad, monitoreo, acceso privilegiado, cliente y requisitos regulatorios antes de la aprobación.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]
- Fecha de revisión: [DATE]

1. Propósito

Esta política establece requisitos para conceder, utilizar, revisar, cambiar y revocar el acceso a información, sistemas, servicios, instalaciones y funciones administrativas [ORGANIZATION].

2. Alcance

Se aplica a [USERS, WORKFORCE, CONTRACTORS, SERVICE ACCOUNTS, APPLICATIONS, DEVICES, THIRD PARTIES, CLOUD AND ON-PREMISES SYSTEMS].

3. Necesidades

3.1 Identidad

Cada usuario debe utilizar una identidad única aprobada a menos que una excepción técnica documentada permita una cuenta controlada compartida o funcional. Los registros de identidad deben ser rastreables para un propietario responsable.

3.2 Autorización

El acceso debe ser aprobado por [DATA/SYSTEM/PROCESS OWNER], basado en necesidades empresariales, mínimo privilegio, segregación de deberes y definiciones de función aprobadas.

3.3 Autenticación

La fuerza de autenticación debe reflejar el riesgo. Se requiere autenticación multifactorial para [DEFINED SYSTEMS, REMOTE ACCESS, PRIVILEGED ACCESS, AND OTHER USE CASES], sujeto a alternativas aprobadas y alojamientos de accesibilidad.

3.4 Acceso privilegiado

El acceso anticipado debe ser autorizado, limitado, supervisado, revisado y utilizado únicamente para actividades administrativas aprobadas. El acceso a emergencias debe tener tiempo y ser revisado después de su uso.

3.5 Controles de unión, mudanza y de levadura

El acceso debe ser proporcionado, modificado, suspendido y revocado dentro de [TIMEFRAMES] sobre la base de la fuerza de trabajo autorizada o los eventos contractuales. Las excepciones y las notificaciones fallidas deben conciliarse e intensificarse.

3.6 Examen del acceso

Los propietarios deben revisar el acceso al menos [FREQUENCY] y después del papel material, sistema, riesgo o cambios organizativos. Los comentarios deben cubrir acceso privilegiado, inactivo, servicio, tercero y conflictivo.

3.7 Identidades de servicio y máquina

Cuentas de servicio, credenciales de API, certificados, secretos e identidades de máquina deben tener propietarios, propósito documentado, mínimo privilegio, almacenamiento seguro, rotación, monitoreo y controles de jubilación.

Acceso remoto y de terceros

El acceso remoto y de terceros debe utilizar métodos aprobados, plazos definidos, controles de seguridad, registro y procedimientos de terminación.

3.9 Registro y seguimiento

La autenticación, autorización, actividad privilegiada, cambios de acceso y fallos significativos deben ser registrados y monitoreados de acuerdo con la Política de Registro y Vigilancia y las normas de privacidad aplicables.

4. Excepciones

Las excepciones requieren riesgo documentado, controles compensatorios, propietario, expiración y aprobación por [AUTHORITY].

5. Documentos

Retener solicitudes, aprobaciones, registros de provisiones, revisiones, excepciones, registros y pruebas de revocación según [RETENTION REQUIREMENT].

6. Ejecución y examen

Las violaciones se tratan con arreglo a procedimientos aprobados y a la legislación aplicable. Esta política se revisa al menos [FREQUENCY] y después de la identidad material, la tecnología, el cambio legal o organizativo.

Plantilla de política de uso aceptable

Revise la fuerza de trabajo, monitoreo, privacidad, trabajo, accesibilidad, denunciantes y requisitos de derecho local antes de la adopción.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]

- Fecha de revisión: [DATE]

1. Propósito

Esta política define el uso aceptable y prohibido de [ORGANIZATION] información, tecnología, comunicaciones, cuentas, redes, dispositivos, instalaciones y servicios.

2. Alcance

Se aplica a [WORKFORCE, CONTRACTORS, TEMPORARY PERSONNEL, VOLUNTEERS, THIRD PARTIES, DEVICES, NETWORKS, CLOUD SERVICES, AND PERSONALLY OWNED DEVICES WHEN AUTHORIZED].

3. Funciones generales

Los usuarios deben:

- utilizar los recursos principalmente para fines autorizados;
- proteger credenciales, dispositivos, información y acceso físico;
- seguir los requisitos de clasificación, manejo, retención, privacidad y registro;
- reportar rápidamente pérdidas, sospechas de compromiso, contenido prohibido, incidentes o fallo de control;
- cumplir con licencias, derechos de propiedad intelectual, contratos y leyes aplicables;
- evite acciones que creen un riesgo de seguridad irrazonable, operativo, legal o de reputación.

4. Actividades prohibidas

A menos que se autorice expresamente por derechos legítimos, los usuarios no deben:

- acceso, alterar, divulgar, copiar o destruir información sin autorización;
- - evitar controles de seguridad, vigilancia, acceso o licencias;
- instalar software, servicios, extensiones o dispositivos no aprobados;
- introducir malware, realizar pruebas no autorizadas o interferir con los servicios;
- compartir credenciales o utilizar la identidad de otra persona;
- utilizar recursos para acoso, discriminación, represalias, vigilancia ilegal, fraude, robo o contenido prohibido;
- almacenar información organizativa en cuentas o servicios personales no aprobados;
- hacer declaraciones o compromisos públicos no autorizados en nombre de [ORGANIZATION];
- utilizar herramientas generativas AI o externas con información restringida contraria a los requisitos aprobados.

5. Uso personal limitado

[ORGANIZATION POLICY ON PERSONAL USE]. El uso personal no debe interferir en el trabajo, consumir recursos irrazonables, crear riesgos, violar la ley o la política, o implicar la aprobación de la organización.

6. Vigilancia y privacidad

El uso puede ser registrado, supervisado, revisado o divulgado únicamente según lo autorizado por la ley, la política, los contratos, las notificaciones y los procedimientos aprobados. Esta cláusula debe adaptarse a la privacidad local y a los requisitos laborales. No elimina los derechos que no pueden ser renunciados legalmente.

7. Trabajo remoto y uso móvil

Los usuarios deben seguir los requisitos aprobados de acceso remoto, seguridad de dispositivos, privilegio físico, viajes y gestión de información. La pérdida o el robo debe ser reportado dentro de [TIMEFRAME].

8. AI y automatización

Los usuarios deben seguir [AI USE POLICY OR STANDARD], validar salidas, proteger información confidencial y personal, respetar la propiedad intelectual y mantener la responsabilidad humana por las decisiones.

9. Excepciones

Las excepciones requieren necesidad comercial documentada, revisión de riesgos, controles compensatorios, duración y aprobación por [AUTHORITY].

10. Ejecución y reconocimiento

Las violaciones pueden dar lugar a medidas correctivas, disciplinarias, contractuales o jurídicas compatibles con la legislación aplicable y las garantías procesales. Los registros de reconocimiento deben ser retenidos según [RETENTION REQUIREMENT].

Plantilla de política de respuesta de incidentes

**** Nota de redacción:**** Resolver y adaptar los requisitos legales, reglamentarios, contractuales, de privacidad, seguros, cumplimiento de la ley, privilegios y notificación de incumplimiento antes de su aprobación.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]

- Fecha de revisión: [DATE]

1. Propósito

Esta política establece la gobernanza para prepararse, detectar, informar, analizar, contener, erradicar, recuperarse y aprender de ciberseguridad, privacidad, tecnología e incidentes de información.

2. Alcance

Se aplica a [ENTITIES, WORKFORCE, SYSTEMS, DATA, FACILITIES, CLOUD, OPERATIONAL TECHNOLOGY, SUPPLIERS, AND SERVICES].

3. Gobernanza

[INCIDENT RESPONSE LEADER] coordina la respuesta. Legal, privacy, communications, human resources, business continuity, technology, security, records, insurance, and executive stakeholders participate according to incident type and severity.

4. Reporting

Los incidentes sospechosos deben ser reportados inmediatamente a través de [CHANNELS]. El personal debe conservar las pruebas y no debe llevar a cabo investigaciones, comunicaciones o reparaciones no autorizadas que puedan aumentar los daños.

5. Clasificación y escalada

Los incidentes deben clasificarse usando [SEVERITY MODEL], considerando seguridad, operaciones, datos, clientes, derechos legales, impacto financiero, terceros e interés público. Los plazos de escalada son [TIMEFRAMES].

6. Necesidades de respuesta

La organización debe mantener y ejercer capacidades para:

- preparación y gestión de contactos;
- detección y ingestión;
- triage and analysis;
- la contención y las decisiones sobre los riesgos institucionales;
- erradicación y recuperación segura;
- preservación de pruebas y cadena de custodia;
- legal, privacy, contractual, insurer, customer, regulator, and law-enforcement coordination;
- comunicaciones internas y externas;
- post-incident review and corrective action.

7. Autoridad de decisión

En [INCIDENT RESPONSE PLAN] se debe asignar autoridad para el aislamiento del sistema, el cierre de los servicios, la comunicación pública, las decisiones relacionadas con el rescate, la notificación de clientes, la notificación de reguladores y la remisión del cumplimiento de la ley.

8. Pruebas y registros

Los registros de incidentes deben ser exactos, sellados con el tiempo, controlados por el acceso y retenidos según requisitos legales de retención, privilegio, privacidad, contrato, seguro y registro.

9. Terceros

Los contratos y los procedimientos operativos deben definir la presentación de informes, cooperación, pruebas, notificación, recuperación y obligaciones posteriores al incidente.

10. Ejercicios y mejora

Los planes deben ser probados al menos [FREQUENCY] y después del cambio de material. Las lecciones y las acciones correctivas deben ser asignadas, rastreadas, validadas e informadas.

11. Excepciones

Las excepciones requieren riesgo documentado, duración, controles compensatorios y aprobación por [AUTHORITY].

Plantilla de políticas de continuidad empresarial y recuperación de desastres

Adaptar los requisitos de seguridad, gestión de emergencia, regulación, contrato, seguro, trabajo, accesibilidad y resiliencia local antes de la aprobación.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]
- Fecha de revisión: [DATE]

1. Propósito

Esta política establece requisitos para proteger a las personas, mantener o restaurar productos y servicios prioritarios, recuperar tecnología e información, y coordinar la respuesta a eventos disruptivos.

2. Alcance

Se aplica a [ENTITIES, LOCATIONS, BUSINESS SERVICES, TECHNOLOGY, INFORMATION, WORKFORCE, FACILITIES, SUPPLIERS, AND DEPENDENCIES].

3. Gobernanza

[EXECUTIVE SPONSOR] proporciona supervisión. [CONTINUITY OWNER] mantiene el programa. Los propietarios de servicios de negocios identifican prioridades y dependencias. Los propietarios de tecnología mantienen capacidades de recuperación alineadas con los objetivos aprobados.

4. Análisis del impacto empresarial

Las actividades prioritarias deben haber documentado el análisis de impacto que abarca la seguridad, cliente, legal, operacional, financiera, datos, proveedor y consecuencias de reputación con el tiempo.

5. Objetivos de recuperación

La administración debe aprobar objetivos de tiempo de recuperación, objetivos de puntos de recuperación, niveles mínimos de servicio, perturbación máxima tolerable y supuestos de dependencia para [DEFINED SERVICES].

6. Planes

La organización debe mantener planes accesibles y controlados para la gestión de crisis, la continuidad de las operaciones, la recuperación en casos de desastre tecnológico, las comunicaciones, la continuidad de la fuerza de trabajo, las instalaciones y la perturbación de los proveedores, según proceda.

7. Respaldo y recuperación

Los respaldos deben ser monitorizados, probados, retenidos y separados según el riesgo. Los procedimientos de recuperación deben abordar la integridad, la autorización, la priorización, las dependencias y asegurar el regreso a las operaciones normales.

8. Resiliencia de terceros

Los proveedores y servicios críticos deben evaluarse para la capacidad de continuidad, la concentración, la tecnología, la financiación y el riesgo de transición. Los contratos deben definir las obligaciones de continuidad, ensayo, notificación, recuperación y salida.

9. Ejercicios y validación

Los planes y las capacidades de recuperación deben ser ejercidos al menos [FREQUENCY] y después de cambios materiales. Los exámenes deben tener objetivos, escenarios, participantes, resultados, excepciones y acciones correctivas. Una tabla exitosa no prueba la recuperación técnica.

10. Activación y comunicación

La autoridad de activación, el comando de incidentes, la comunicación de empleados, la comunicación de clientes y reguladores, y las decisiones de retorno a lo normal deben definirse en planes aprobados.

11. Registros y mejoras

Retener análisis de impacto, planes, aprobaciones, pruebas, evidencia de recuperación, incidentes, comunicaciones y acciones correctivas según [RETENTION REQUIREMENT].

12. Excepciones

Las excepciones requieren riesgo documentado, medidas provisionales, propietario, expiración y aprobación por [AUTHORITY].

Plantilla de políticas de riesgo de terceros y proveedores

Adaptar las adquisiciones, competencia, externalización, privacidad, sector, sanciones, registros, trabajos, financieros y requisitos contractuales antes de su aprobación.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]
- Fecha de revisión: [DATE]

1. Propósito

Esta política establece requisitos para identificar, evaluar, aprobar, contratar, supervisar, cambiar y poner fin a las relaciones de terceros y los riesgos asociados de cadena de suministro.

2. Alcance

Se aplica a [SUPPLIERS, CONTRACTORS, CONSULTANTS, CLOUD PROVIDERS, PROCESSORS, SUBPROCESSORS, OUTSOURCERS, PARTNERS, SOFTWARE, HARDWARE, DATA, AND OTHER THIRD PARTIES].

3. Inventario y propiedad

Todas las relaciones in-scope deben ser registradas en [AUTHORITATIVE REGISTER] con un propietario de negocios, descripción de servicios, acceso a datos y sistemas, criticidad, ubicaciones, subprocesadores, fechas de contrato y dependencias de salida.

4. Clasificación de riesgos

Los terceros deben vincularse antes del compromiso utilizando criterios como la crítica de servicios, la sensibilidad de la información, el acceso privilegiado, la dependencia operacional, la concentración, la exposición financiera, la geografía, la pertinencia reglamentaria, la recuperabilidad y la sustitución.

5. Due diligence

La diligencia debida debe ser proporcional al riesgo y puede abarcar seguridad, privacidad, resiliencia, legal, cumplimiento, financiera, sanciones, seguros, ética, accesibilidad, fuerza de trabajo y dependencias de cuartas partes. Deben documentarse las limitaciones de las pruebas y los resultados no resueltos.

6. Decisiones de aprobación y riesgo

El propietario del negocio, adquisición, legal, privacidad, seguridad, cumplimiento y otras funciones requeridas deben aprobarse según [AUTHORITY MATRIX]. Los riesgos y excepciones residuales exigen una aceptación responsable.

7. Recursos necesarios por contrata

Los contratos deben abordar los requisitos aplicables para la seguridad, la privacidad, la confidencialidad, las restricciones de uso, la auditoría y la seguridad, la notificación de incidentes, la cooperación, la continuidad de las operaciones, los subcontratistas, la ubicación, la devolución o eliminación de datos, los registros, el seguro, la responsabilidad, la terminación y la transición.

8. Supervisión continua

La frecuencia de vigilancia y la profundidad deben reflejar el riesgo. Los exámenes de los desencadenantes incluyen incidentes, fallos de control, cambios materiales, adquisiciones, deterioro financiero, nuevos subprocesadores, cambios de ubicación, medidas reglamentarias y fallos de servicio repetidos.

9. Acceso y datos

El acceso de terceros y el procesamiento de datos deben ser autorizados, menos privilegiados, con plazos, cuando sea posible, registrados, revisados y revocados al término. Los datos deben ser devueltos, transferidos, retenidos o eliminados de forma segura según los requisitos aprobados.

10. Resiliencia y salida

Las relaciones críticas deben tener planes de continuidad, recuperación, transición y salida. Hay que considerar la concentración, el bloqueo, la transferencia de conocimientos, la portabilidad de datos y el tiempo de sustitución.

11. Documentos

Retener evaluaciones, aprobaciones, contratos, pruebas, hallazgos, monitoreo, incidentes, excepciones, rescisión y cancelación o confirmación de devolución según [RETENTION REQUIREMENT].

12. Excepciones

Las excepciones requieren justificación documentada, riesgo, controles compensatorios, propietario, duración, monitoreo y aprobación por [AUTHORITY].

Plantilla de Protección de Datos y Política de Privacidad

Esta plantilla requiere privacidad y revisión jurídica específicas para la jurisdicción. No asuma una ley de privacidad, una base legal, un período de retención, una norma de vigilancia de los empleados o un mecanismo transfronterizo se aplica universalmente.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [PRIVACY OR POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]
- Fecha de revisión: [DATE]

1. Propósito

Esta política establece principios y gobernanza para el procesamiento legal, justo, transparente, seguro y responsable de la información personal por [ORGANIZATION].

2. Alcance

Se aplica a [LEGAL ENTITIES, WORKFORCE, CUSTOMERS, USERS, APPLICANTS, CHILDREN OR VULNERABLE PEOPLE IF APPLICABLE, THIRD PARTIES, SYSTEMS, LOCATIONS, AND PROCESSING ACTIVITIES].

3. Principios

La información personal debe ser:

- tramitados bajo una autoridad legal identificada o con fines permitidos;
- recogidos para fines específicos y no reutilizados incompatiblemente;
- limitado a lo que es necesario;
- precisa y corregida cuando sea necesario;
- retenido únicamente como autorizado;
- protegidos según el riesgo;
- y con una gobernanza responsable;

- manejado de una manera que apoye los derechos y recursos aplicables.

4. Registros de procesamiento

En [PRIVACY INVENTORY OR RECORD] se deben registrar las actividades de procesamiento en el lugar, incluyendo propósito, categorías, individuos, sistemas, receptores, ubicaciones, base legal, retención, seguridad, transferencias y propietario.

5. Privacidad por diseño

Los proyectos, productos, adquisiciones, análisis, IA, monitoreo y cambios materiales deben incluir la revisión de la privacidad lo antes posible para influir en las decisiones. El procesamiento de alto riesgo requiere [IMPACT ASSESSMENT PROCESS].

6. Avisos, opciones y consentimiento

Los avisos y las opciones deben ser claras, accesibles, precisas y proporcionadas cuando sea necesario. El consentimiento debe utilizarse únicamente cuando sea válido y gestionado según los requisitos aplicables; no debe presentarse como base universal para el procesamiento.

7. Derechos individuales

Las solicitudes de acceso, corrección, supresión, objeción, restricción, portabilidad, retiro, apelación u otros derechos aplicables deben ser autenticadas, registradas, evaluadas, cumplidas o legalmente denegadas dentro de [TIMEFRAMES].

8. Compartir y terceros

La información personal sólo podrá compartirse con fines autorizados con contratos apropiados, diligencia debida, controles de acceso, mecanismos de transferencia y supervisión continua.

9. Proceso internacional y transfronterizo

El procesamiento transfronterizo debe evaluarse y apoyarse mediante mecanismos válidos para las jurisdicciones aplicables. Los lugares y las transferencias a continuación deben ser documentados.

10. Retención y eliminación

La retención debe seguir los horarios aprobados, las garantías legales, las obligaciones contractuales y las necesidades comerciales documentadas. El despojo debe ser seguro y verificable.

11. Seguridad e incidentes

La información personal debe estar protegida por salvaguardias basadas en el riesgo. Los incidentes de privacidad sospechosos deben ser reportados a través de [CHANNEL] y gestionados bajo la Política de Respuesta de Incidentes, incluido el análisis de notificación.

12. Fuerza de trabajo y vigilancia

Los empleados, contratistas y el procesamiento del lugar de trabajo requieren una revisión legal específica, laboral, nota, proporcionalidad y acceso. Esta sección debe adaptarse localmente.

13. Responsabilidad

[PRIVACY OFFICER OR RESPONSIBLE ROLE] supervisa el programa. Los propietarios de empresas y sistemas siguen siendo responsables de sus actividades de procesamiento, registros, controles y acciones correctivas.

14. Excepciones y ejecución

Excepciones requieren revisión legal y de privacidad, riesgo documentado, duración, controles y aprobación por [AUTHORITY]. Las violaciones se tratan en virtud de procedimientos y leyes aplicables.

Gestión del cambio Policy Template

Adaptar la seguridad, sistema regulado, desarrollo de software, tecnología operativa, segregación de deber, cambio de emergencia, registros y requisitos de cliente antes de la aprobación.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]
- Fecha de revisión: [DATE]

1. Propósito

Esta política establece requisitos para planificar, evaluar, autorizar, probar, implementar, documentar, revisar y invertir cambios en la tecnología [ORGANIZATION], información, servicios, instalaciones, configuraciones y procesos controlados.

2. Alcance

Se aplica a [APPLICATIONS, INFRASTRUCTURE, CLOUD, NETWORKS, SECURITY CONTROLS, DATA, OPERATIONAL TECHNOLOGY, FACILITIES, VENDORS, AND CONTROLLED BUSINESS PROCESSES].

3. Categorías del cambio

Los cambios deben clasificarse como [STANDARD, NORMAL, EMERGENCY, MAJOR, OR OTHER APPROVED CATEGORIES] utilizando criterios documentados. La clasificación no debe ser manipulada para evitar la revisión.

4. Registro de cambios

Cada cambio no exento debe registrar:

- solicitante, propietario e implementador;
- fines empresariales y servicios afectados;
- el alcance, las dependencias y el calendario;
- seguridad, privacidad, resiliencia, datos, cliente e impacto regulatorio;
- criterios de prueba y aceptación;
- la aplicación y el plan de devolución;
- aprobaciones;
- comunicaciones;
- resultado, excepciones y examen posterior a la ejecución.

5. Evaluación y aprobación del riesgo

La autoridad encargada de examinar la profundidad y la aprobación debe reflejar el riesgo, la crítica, la separación de funciones y los posibles efectos. Los revisores requeridos pueden incluir funciones de negocios, tecnología, seguridad, privacidad, continuidad, arquitectura, datos, proveedor, legal y cumplimiento.

6. Pruebas

Los cambios deben probarse en un entorno adecuado antes de la producción a menos que se aplique un proceso de emergencia aprobado. Los datos de prueba deben ser autorizados y protegidos. Los resultados y las limitaciones no resueltas deben documentarse.

7. Segregation of duties

Las responsabilidades de desarrollo, aprobación y ejecución de la producción deben separarse cuando sea factible y proporcional al riesgo. Los conflictos requieren vigilancia y aprobación.

8. Cambios de emergencia

Los cambios de emergencia pueden utilizar la aprobación acelerada únicamente para hacer frente a los riesgos o necesidades de servicios urgentes. Deben ser documentados, autorizados por [EMERGENCY AUTHORITY], monitoreados y revisados retrospectivamente dentro de [TIMEFRAME].

9. Cambios estándar

Los cambios estándar preautorizados deben ser de bajo riesgo, repetibles, documentados, probados, monitoreados y revisados periódicamente. Las condiciones fallidas o modificadas requieren reclasificación.

10. Examen de la aplicación posterior

Los cambios importantes, fallidos, de emergencia, sensibles a la seguridad o de alto riesgo requieren un examen de los resultados, incidentes, retrocesos, efectos de control, documentación y lecciones.

11. Cambios no autorizados

Los cambios no autorizados o indocumentados deben ser investigados, contenidos cuando sea necesario, reportados y abordados mediante medidas correctivas.

12. Registros, métricas y excepciones

Retener registros de cambio de acuerdo a [RETENTION REQUIREMENT]. Supervisar cambios fallidos, cambios de emergencia, cambios no autorizados, retroceso, incidentes y exámenes atrasados. Las excepciones requieren riesgo documentado, controles, duración y aprobación por [AUTHORITY].

Plantilla de Política de Gestión de Vulnerabilidad y Patch

Adapte requisitos de seguridad de productos, médicos, industriales, de tecnología operacional, nube, proveedor, contractuales, finales de vida y reglamentarios antes de su aprobación.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]
- Fecha de revisión: [DATE]

1. Propósito

Esta política establece requisitos para identificar, evaluar, priorizar, tratar, validar y reportar vulnerabilidades y actualizaciones de seguridad que afectan a activos y servicios de [ORGANIZATION].

2. Alcance

Se aplica a [HARDWARE, SOFTWARE, FIRMWARE, CLOUD, APPLICATIONS, NETWORKS, ENDPOINTS, CONTAINERS, OPERATIONAL TECHNOLOGY, MOBILE, THIRD-PARTY SERVICES, AND INTERNET-FACING ASSETS].

3. Requisitos de activos y propiedad

Los activos in-scope deben inventoriarse con el propietario, la crítica, la exposición, la tecnología, el estado de apoyo y el servicio de negocios. Deben informarse y abordarse los activos y las deficiencias de propiedad desconocidas.

4. Identificación de vulnerabilidad

[ORGANIZATION] debe utilizar fuentes y métodos aprobados como escaneo autenticado, pruebas de aplicaciones, evaluación de la nube, notificaciones de proveedores, inteligencia de amenazas, revisión de configuración, pruebas de penetración, análisis de códigos y divulgación coordinada.

Los ensayos deben ser autorizados, planificados con seguridad y apropiados para el medio ambiente.

5. Priorización

La prioridad del tratamiento debe considerar más que una puntuación técnica. Los criterios incluyen pruebas de explotación, exposición, crítica de activos, datos, privilegios, trayectoria de ataque, controles compensatorios, impacto empresarial, seguridad, recuperabilidad y orientación de proveedores.

6. Plazos de tratamiento

Los objetivos de tratamiento aprobados son [DEFINE BY SEVERITY AND CONTEXT]. Los plazos comienzan en [DEFINED EVENT] y pueden ser acortados para la explotación activa, la exposición a Internet, servicios críticos o derechos regulatorios.

7. Opciones de tratamiento

El tratamiento puede incluir parche, cambio de configuración, actualización, eliminación, aislamiento, control compensatorio, restricción de servicios, aceptación de riesgos o reemplazo. Las decisiones deben abordar la exposición a la raíz y documentarse.

8. Pruebas y despliegue

Las actualizaciones deben ser probadas proporcionales al riesgo y desplegadas mediante la gestión de cambios aprobada. El tratamiento de emergencia puede utilizar procedimientos acelerados. Debe considerarse la posibilidad de retroceso, respaldo, compatibilidad y continuidad de servicio.

9. Excepciones y aceptación del riesgo

Los objetivos de tratamiento perdidos requieren un riesgo documentado, justificación comercial y técnica, controles provisionales, propietario, expiración, monitoreo y aprobación por [AUTHORITY]. Las extensiones repetidas requieren escalada.

10. Validación

El cierre requiere evidencia de que la vulnerabilidad es remediada o tratada de otro modo. Rescanning, verificación de configuración, confirmación de la versión o validación equivalente debe ser independiente de la afirmación del propietario sin soporte.

11. Proveedores y tecnología sin soporte

Las vulnerabilidades gestionadas por los proveedores, los activos al final de la vida y los parches no disponibles requieren coordinación documentada, acción contractual, controles compensatorios, migración y escalada.

12. Divulgación e información

Los informes de vulnerabilidad externa deben seguir [DISCLOSURE PROCESS]. Las métricas internas deben abarcar la cobertura, la edad, la exposición atrasada, la explotación activa, las excepciones, la recurrencia, los activos no respaldados y los fallos de validación.

13. Documentos y examen

Retener inventarios, resultados de exploración, entradas, aprobaciones, excepciones, validación, correspondencia con proveedores y métricas según [RETENTION REQUIREMENT].

Plantilla de política de seguimiento y seguimiento

Adaptar la privacidad, la vigilancia de la fuerza de trabajo, el secreto de las comunicaciones, los privilegios, los registros, la investigación, el sector y los requisitos transfronterizos antes de su aprobación.

Control de documentos

- Policy ID: [POLICY ID]
- Propietario: [POLICY OWNER]
- Cambio de imagen: [APPROVING AUTHORITY]
- Fecha efectiva: [DATE]
- Fecha de revisión: [DATE]

1. Propósito

Esta política establece requisitos para generar, recopilar, proteger, retener, revisar y utilizar registros e información de monitoreo para apoyar la seguridad, privacidad, operaciones, resiliencia, investigaciones, cumplimiento y rendición de cuentas.

2. Alcance

Se aplica a [APPLICATIONS, CLOUD, NETWORKS, ENDPOINTS, IDENTITY, DATABASES, SECURITY TOOLS, OPERATIONAL TECHNOLOGY, FACILITIES, THIRD PARTIES, AND BUSINESS-CRITICAL SERVICES].

3. Necesidades de registro

Los propietarios deben definir los eventos requeridos basados en el riesgo y las obligaciones. Los acontecimientos pertinentes pueden incluir:

- autenticación y decisiones de acceso;
- actividad privilegiada y administrativa;
- cambios en la cuenta y el permiso;
- cambios en el control de la seguridad;
- cambios de configuración y despliegue;
- acceso a datos, exportación, eliminación y procesamiento de alto riesgo;
- sistema, aplicación, red y fallas de servicio;
- Detección de malware, vulnerabilidad y amenazas;
- - medidas de respuesta a incidentes;
- respaldo, recuperación y eventos de continuidad;
- acceso de terceros y eventos significativos de proveedores.

4. Calidad de la memoria

Los registros deben tener suficiente tiempo de sincronización, identidad fuente, detalle de eventos, integridad y contexto para apoyar su uso previsto. No se deben registrar datos sensibles, credenciales, secretos e información personal innecesaria a menos que estén específicamente autorizados y protegidos.

5. Colección y disponibilidad

Los registros críticos deben ser transmitidos o protegidos para reducir la alteración o pérdida no autorizada. Los sistemas de vigilancia deben tener capacidad, disponibilidad, control de acceso, respaldo y vigilancia de la salud proporcional al riesgo.

6. Retención

Los plazos de retención deben ser definidos por [RETENTION SCHEDULE], considerando la investigación, las operaciones, los contratos, la privacidad, las garantías legales y los deberes regulatorios. La retención más larga no es automáticamente más segura y debe tener un propósito documentado.

7. Acceso y confidencialidad

El acceso a registros y herramientas de monitoreo debe ser menos privilegiado, aprobado, registrado y revisado periódicamente. El acceso a la investigación y supervisión de los empleados requiere controles legales, de privacidad, de recursos humanos y laborales aplicables.

8. Vigilancia y respuesta

Deben documentarse casos, umbrales de alerta, propiedad, gravedad, escalada, tiempo de respuesta y requisitos de evidencia. Las alertas deben ser probadas y sin suprimir el riesgo material.

9. Terceros

Los contratos e integraciones deben abordar la disponibilidad de registros, notificación, acceso, retención, sincronización de tiempo, apoyo a la investigación y transferencia segura cuando corresponda.

10. Privacidad y proporcionalidad

La vigilancia debe tener un propósito documentado, autoridad legal, alcance proporcional, aviso cuando sea necesario, restricciones de acceso, límites de retención y revisión. Esta política no autoriza la vigilancia ilegal o indiscriminada.

11. Validación y métrica

Validar la cobertura de la fuente, ingestión, parsing, precisión del tiempo, operación de alerta, retención, búsqueda, control de acceso y respuesta. Las métricas deben cubrir lagunas de cobertura, fallos de fuente, retrasos de alerta, falsos positivos, tiempos de respuesta y eventos de alto riesgo no revisados.

12. Excepciones y registros

Las excepciones requieren riesgo documentado, controles compensatorios, propietario, duración, monitoreo y aprobación por [AUTHORITY]. Retener configuración, utilizar casos, exámenes de acceso, pruebas, alertas, investigaciones, excepciones y acciones correctivas según los requisitos aprobados.